

Préparation à la certification CEH

Dr N'GORAN K. Rodrigue
Ingénieur Docteur en Informatique option Cybersécurité

ESATIC

Mar. 2026

Sommaire

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web

1. Introduction au Hacking Éthique

2. Présentation de la certification CEH

3. Attaques sur les applications web

Ethical hacking ou hacking éthique

- ▶ Méthodes de découverte et d'exploitation **de vulnérabilités** (tests d'intrusion...) **de façon légale avec l'autorisation des propriétaires** d'un système dans le but de l'améliorer
- ▶ Sécuriser un système sans en tirer **un profit de manière illicite**
- ▶ Comprendre les stratégies **malveillantes** et **s'en défendre**

Identification et évaluation des vulnérabilités

- ▶ **Techniques d'analyse** : Analyse approfondie des protocoles réseau, configuration système, applications web, etc. Combinaison d'observations passives et de tests actifs à travers des tests d'intrusion(pentesting).
- ▶ **Rapport et recommandations** : Élaboration d'un rapport exhaustif et de qualité qui expose chaque faille détectée. Ce rapport comporte des recommandations de corrections des vulnérabilités (modification de code, mises à jour de logiciels, etc).
Étape importante qui distingue le hacker éthique du hacker malveillant

Mise en œuvre de mesures de sécurité

Le hacker éthique recommande et accompagne la mise en œuvre des mesures de sécurité à travers :

- ▶ **La collaboration avec les équipes** : de développement, d'administration système, de sécurité, etc.
- ▶ **La formation et sensibilisation** : du personnel (utilisateurs) aux bonnes pratiques de sécurité informatique (ateliers, séminaires de formations).

Le rôle d'un hacker éthique est à la fois **préventif et éducatif**

Informations personnelles et données sensibles

Les lois sur la protection des données, comme **la loi n 2013-450 du 19 juin 2013 en Côte d'Ivoire et le RGPD (Règlement Général sur la Protection des Données) (entrée en vigueur le 25 mai 2018 dans l'Union européenne)** imposent aux organisations :

- ▶ Des contrôles sur la manière dont les données personnelles doivent être collectées (minimisation), traitées et stockées (durée limitée)
- ▶ De s'assurer que les données sont protégées contre l'accès non autorisé et le vol
- ▶ De disposer du consentement des utilisateurs

Informations personnelles et données sensibles

- Possibilité de se conformer à des normes spécifiques comme la norme ISO/IEC 27001 (définit les exigences d'un SMSI (système de gestion de la sécurité des systèmes d'informations))

Section 1: Introduction au Hacking Éthique

9

Les différentes catégories de hackers

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web



Section 1: Introduction au Hacking Éthique

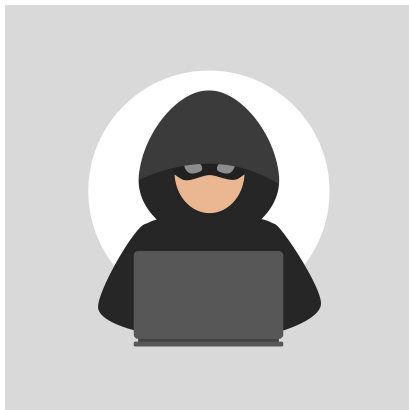
9

Les différentes catégories de hackers

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web



Qu'est-ce qu'un Hacker ?

- ▶ Origine : **To Hack**
- ▶ **Découper** un objet à l'aide d'un outil
- ▶ Découper des informations **en blocs logiques** et les réassembler
- ▶ **Modifier le fonctionnement** d'un système pour **l'améliorer**
- ▶ **Détourner un système** de son but premier (la protection)
- ▶ Deux choix : **malveillant** ou **bienveillant**

Hacker white hat

- ▶ Agis dans la : **légalité**
- ▶ Recherche à se **protéger** ou à **protéger d'autres systèmes**
- ▶ L'objectif de la **certification CEH** est de devenir un **white hat hacker** !

Hacker black hat

- ▶ Agis dans un but : **personnel** et de façon illégale
- ▶ Vol, altération de données, motivés par un gain financier ou nuire à autrui
- ▶ À l'origine de **virus, chevaux de Troie, logiciels espions**

Hacker grey hat

- ▶ Intention : **mitigée (ni Black, ni White)**
- ▶ Recherche de failles sans autorisation et alerte de façon **illégale ou contre rémunération**

Hackers red hat

- ▶ Se présentent comme : **des justiciers** du cyberspace
- ▶ Ils traquent **activement** les black hat et les neutralisent
- ▶ Leur approche offensive, bien que motivée par la lutte contre la cybercriminalité, s'éloigne du cadre légal et peut générer des dommages collatéraux.

Hacktivistes

- ▶ Combinent : **activisme et hacking**
- ▶ Défendent des **causes politiques, sociales ou idéologiques**
- ▶ Ils ciblent des **entreprises, gouvernements ou organisations qu'ils jugent contraires à leurs valeurs**

Script kiddies

- ▶ **Novices** qui utilisent des scripts sans en comprendre réellement le fonctionnement
- ▶ **Motivation principale** : Curiosité, la reconnaissance ou distraction.
- ▶ Peuvent causer **des dégâts réels** sur des cibles vulnérables

Hackers étatiques (state-sponsored hackers)

- ▶ Opèrent pour le compte **d'un gouvernement**
- ▶ **Missions** : espionnage industriel, déstabilisation politique, collecte de renseignements militaires
- ▶ Disposent de **ressources considérables et de moyens techniques sophistiqués**
- ▶ Représentent une **menace majeure** car leurs opérations sont **planifiées, ciblées et difficiles à attribuer publiquement**

Insiders (acteurs internes)

- ▶ Il peut s'agir **d'employés, de sous-traitants ou de prestataires** disposant d'un **accès légitime** aux systèmes, mais qui **abusent de ces privilèges**
- ▶ **Motivations** : vengeance, idéologie, appât du gain, simple négligence, etc.
- ▶ Sont **redoutables**, exploitent **la confiance accordée**, **échappent parfois** aux contrôles de sécurité classiques

Insiders (acteurs internes)

- ▶ Il peut s'agir **d'employés, de sous-traitants ou de prestataires** disposant d'un **accès légitime** aux systèmes, mais qui **abusent de ces privilèges**
- ▶ **Motivations** : vengeance, idéologie, appât du gain, simple négligence, etc.
- ▶ Sont **redoutables**, exploitent **la confiance accordée**, **échappent parfois** aux contrôles de sécurité classiques

- ▶ **Responsable de la sécurité des systèmes d'information (RSSI)** : définit et met en œuvre la politique de sécurité informatique de l'entreprise
- ▶ **Auditeur en sécurité de système d'information (SSI)** : évalue le niveau de sécurité d'une organisation à travers des scénarios réalistes
- ▶ **Consultant en sécurité offensive** : expert technique avec une capacité à accompagner les clients sur leurs choix stratégiques
- ▶ Participant à des programmes de **bug bounty**, membre d'une Red Team, etc.

Section 2: Présentation de la certification CEH 20

Sommaire

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

1. Introduction au Hacking Éthique

2. Présentation de la certification CEH

3. Attaques sur les applications web

Section 2: Présentation de la certification CEH 21

Objectifs, évolution et reconnaissance

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

- ▶ La certification **CEH (Certified Ethical Hacker)** a été lancée en 2003 par l'EC-Council (International Council of E-Commerce Consultants)
- ▶ **Objectif** : former des professionnels capables de **penser comme des attaquants** pour mieux défendre les systèmes d'information
- ▶ CEH est **reconnue mondialement** et **souvent exigée dans les offres d'emploi** (pentester, consultant sécurité, etc.)
- ▶ Constitue une base solide pour des certifications comme **l'OSCP (Offensive Security Certified Professional)**, ou le **CISSP (Certified Information Systems Security Professional)**, ou **CISM (Certified Information Security Manager)**.

Section 2: Présentation de la certification CEH 22

Compétences évaluées

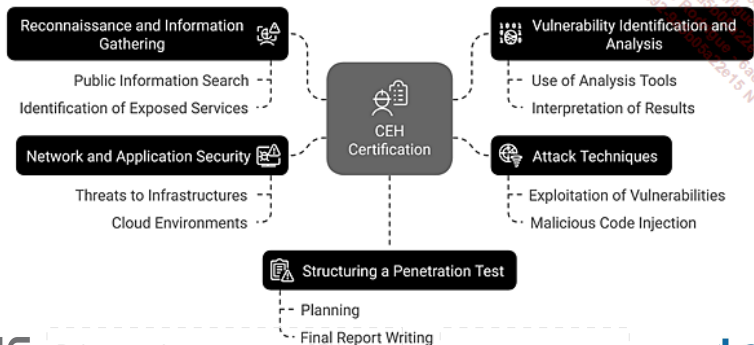
Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

La certification CEH évalue un large éventail de compétences techniques, organisées autour des **différentes phases d'un test d'intrusion (pentest)**.

Skills Assessed by the CEH Certification



Section 2: Présentation de la certification CEH 23

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Versions de la CEH

- ▶ **CEH** : Examen Théorique (version standard)
- ▶ **CEH Practical** : Examen pratique dans environnement virtuel et consistant à exploiter des scénarios réels d'attaque et de défense afin de démontrer les compétences techniques du candidat.
- ▶ **CEH Master** : combinaison CEH et CEH Practical (très valorisé) .

Section 2: Présentation de la certification CEH 24

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Composition de l'examen CEH

Exam Details	
Characteristic	Detail
 Questions	125
 Duration	4 hours
 Format	MCQ
 Required Score	70%
 Topics	Web, networks, IoT, etc.
 Modalities	Online/Pearson VUE

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.
- ▶ Même si l'examen est théorique, **la pratique** reste un levier fondamental

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.
- ▶ Même si l'examen est théorique, **la pratique** reste un levier fondamental
- ▶ Faire **des examens blancs** pour se familiariser avec le format

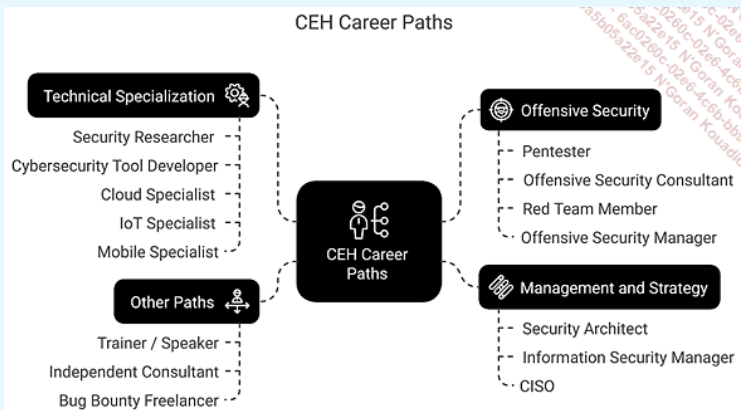
Section 2: Présentation de la certification CEH 26

Avantages professionnels et opportunités de carrière

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web



1. Introduction au Hacking Éthique

2. Présentation de la certification CEH

3. Attaques sur les applications web

- ▶ En 2024, 94 % des applications testées présentaient une vulnérabilité (OWASP) (20 % des applications touchées par des injections).
- ▶ 60 % des PME victimes d'une cyberattaque cessent leurs activités dans les six mois qui suivent (Cybersecurity Ventures).
- ▶ La sécurité web repose sur les principes fondamentaux de la sécurité en occurrence **la confidentialité, l'intégrité et la disponibilité**.
- ▶ Requiert une **approche globale de la sécurité** à travers des mesures **techniques, organisationnelles et humaines** (bonnes pratiques de développement (security by design), tests de sécurité réguliers (pentest), formation et sensibilisation des développeurs, des administrateurs et utilisateurs.

OWASP (Open Web Application Security Project)

- ▶ Une organisation mondiale à but non lucratif fondée en 2001 qui est dédiée à **l'amélioration de la sécurité des logiciels**
- ▶ Fournit des **ressources** (guides, des outils et des documentations) et dispose **d'une communauté** composée de professionnels de la sécurité, de développeurs, de chercheurs et d'organisations collaborant ensemble pour partager des connaissances et de meilleures pratiques.
- ▶ **OWASP Top 10** : un projet de l'OWASP qui répertorie les dix vulnérabilités les plus critiques affectant les applications web (liste est mise à jour régulièrement)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)
6. **A06 :2025** – Conception non sécurisée (Insecure Design)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)
6. **A06 :2025** – Conception non sécurisée (Insecure Design)
7. **A07 :2025** – Défaillances d'authentification (Authentication Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)
3. **A09 :2025** – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)
3. **A09 :2025** – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)
4. **A010 :2025** – Mauvaise gestion des conditions exceptionnelles (Mishandling of Exceptional Conditions)

A01 :2025 – Contrôle d'accès défaillant (Broken Access Control)

- ▶ **Contrôle d'accès** : s'assurer que les utilisateurs authentifiés ne peuvent **accéder qu'aux ressources pour lesquelles ils ont les accès appropriés**
- ▶ **Contrôle d'accès défaillant** : Les restrictions ne sont pas correctement appliquées.
- ▶ **La méthodologie de l'attaque**
 - Modification des URL ou des identifiants pour accéder à des données non autorisées
 - Escalade de privilèges, où un utilisateur standard obtient des droits administratifs
 - Accès à des API non sécurisées permettant des opérations non autorisées

A01 :2025 – Contrôle d'accès défaillant (Broken Access Control)

► Impact

- Accès non autorisé aux données sensibles
- Modification/destruction de données donc une perte d'intégrité
- Compromission du système (contrôle partiel ou total de l'application par un attaquant)

► Exemple

- Un site e-commerce permet aux utilisateurs d'accéder à leurs commandes via une URL du type :
<https://www.ecomcsia.com/commande?id=123456>
- Si l'application ne vérifie pas que l'utilisateur est autorisé à consulter la commande avec l'ID 123456, alors un attaquant authentifié peut modifier l'ID pour accéder aux commandes d'autres clients :
<https://www.ecomcsia.com/commande?id=987654>